Quy trình báo cáo sự cố bảo mật

Phiên bản: 1.3 | Ngày hiệu lực: 01/09/2024 | Đơn vị ban hành: Trung tâm An ninh mạng VinSOC (giả định)

1. Thông tin kiểm soát tài liệu

Hạng mục	Nội dung
Mã tài liệu	SYN-D10
Đơn vị sở hữu	Trung tâm An ninh mạng VinSOC (giả định)
Người phê duyệt	Giám đốc An ninh thông tin
Đối tượng áp dụng	Toàn bộ nhân sự, nhà thầu và đối tác sử dụng thiết bị, tài khoản hoặc dữ liệu của công ty
Phân loại	Nội bộ
Ghi chú	Tài liệu giả lập để kiểm thử, không phải chính sách VSF đã xác nhận

2. Mục đích, phạm vi và căn cứ

2.1 Mục đích

Quy trình này hướng dẫn nhân sự nhận biết, báo cáo và phối hợp xử lý sự cố bảo mật một cách nhanh chóng và thống nhất. Thời gian là yếu tố quyết định: một máy nhiễm mã độc hoặc một tài khoản bị chiếm quyền có thể lan sang nhiều hệ thống chỉ trong vài giờ, vì vậy nhân sự cần biết chính xác phải làm gì và báo cho ai.

2.2 Phạm vi và đối tượng áp dụng

Quy trình áp dụng cho mọi sự cố hoặc nghi ngờ sự cố liên quan đến thiết bị công ty, tài khoản công ty, dữ liệu công ty hoặc hệ thống mạng của công ty, dù xảy ra tại văn phòng, tại nhà hay trong lúc di chuyển. Quy trình áp dụng cho nhân viên chính thức, nhân viên thử việc, thực tập sinh, nhà thầu và đối tác.

2.3 Căn cứ và tài liệu liên quan

- Chính sách phân loại dữ liệu: xác định mức độ nhạy cảm của dữ liệu bị ảnh hưởng.
- Chính sách mật khẩu và xác thực: xử lý mật khẩu và MFA khi tài khoản bị chiếm quyền.
- Chính sách làm việc từ xa: yêu cầu VPN và cách báo khi sự cố xảy ra lúc làm việc từ xa.
- Danh bạ đầu mối theo đội: kênh liên hệ của Trực SOC và IT Helpdesk.
- Nội quy lao động: xử lý vi phạm, gồm cả che giấu sự cố.

3. Định nghĩa và thuật ngữ

Thuật ngữ	Ý nghĩa
Sự cố bảo mật	Sự việc đã xảy ra hoặc có khả năng cao xảy ra làm mất tính bí mật, toàn vẹn hoặc sẵn sàng của thiết bị, tài khoản hoặc dữ liệu
Nghi ngờ sự cố	Dấu hiệu bất thường chưa được xác nhận nhưng có thể là sự cố; vẫn phải báo cáo
Trực SOC	Đầu mối trực 24/7 của VinSOC tiếp nhận báo cáo sự cố bảo mật
Mã sự cố	Mã do Trực SOC cung cấp để theo dõi một sự cố
Mã độc	Phần mềm gây hại như virus, phần mềm tống tiền, phần mềm gián điệp
Chiếm quyền tài khoản	Người khác đăng nhập hoặc điều khiển tài khoản mà chủ tài khoản không cho phép
Dấu vết	Tệp, nhật ký, cửa sổ thông báo và trạng thái máy có thể giúp điều tra
Cô lập	Ngắt thiết bị khỏi mạng để hạn chế lan rộng

4. Vai trò và trách nhiệm

Vai trò	Trách nhiệm chính	Ghi chú
Người phát hiện	Cô lập thiết bị, báo Trực SOC trong 1 giờ, cung cấp thông tin	Bất kỳ nhân sự nào
Quản lý trực tiếp	Hỗ trợ người phát hiện, không ngăn cản việc báo cáo	Không tự điều tra
Trực SOC	Tiếp nhận, cấp mã sự cố, phân loại, hướng dẫn xử lý	Hoạt động 24/7
VinSOC	Điều tra, thu thập bằng chứng, xử lý và rà soát sau sự cố	Chủ sở hữu tài liệu
IT Helpdesk	Thu hồi hoặc cấp lại thiết bị, tài khoản theo yêu cầu của Trực SOC	Phối hợp
Lãnh đạo có thẩm quyền	Quyết định thông báo ra bên ngoài với sự cố nghiêm trọng	Theo đề xuất của VinSOC

5. Khi nào phải báo cáo

Nhân sự phải báo cáo khi phát hiện mã độc trên máy, mất hoặc thất lạc thiết bị công ty, hoặc nghi ngờ tài khoản bị chiếm quyền.

Nguyên tắc chung là khi nghi ngờ thì báo cáo. Nhân sự không cần chắc chắn đó là sự cố thật; việc đánh giá thuộc về Trực SOC. Báo nhầm không bị xử lý, còn không báo hoặc báo muộn có thể làm sự cố nghiêm trọng hơn.

5.1 Những trường hợp được coi là sự cố

Nhóm	Biểu hiện điển hình	Ví dụ
Mã độc	Máy chậm bất thường, hiện cửa sổ lạ, tệp bị mã hóa, phần mềm diệt virus cảnh báo	Xuất hiện yêu cầu trả tiền để mở khóa tệp
Mất thiết bị	Không tìm thấy hoặc bị lấy cắp laptop, điện thoại, thẻ, USB của công ty	Để quên laptop trên xe
Chiếm quyền tài khoản	Đăng nhập lạ, thay đổi cấu hình không do mình, yêu cầu xác nhận MFA không phải của mình	Nhận thông báo đăng nhập từ nơi lạ
Lộ hoặc gửi nhầm dữ liệu	Dữ liệu Nội bộ trở lên gửi nhầm người hoặc để công khai	Gửi bảng lương nhầm nhóm chat
Lừa đảo	Bấm vào liên kết giả, nhập mật khẩu vào trang giả, mở tệp lạ	Điền mật khẩu vào trang giả mạo cổng công ty

5.2 Những trường hợp không phải báo cáo theo quy trình này

- Thư rác thông thường không chứa liên kết hoặc tệp đáng ngờ và chưa bị mở; chuyển vào mục thư rác là đủ.
- Sự cố kỹ thuật thuần túy không liên quan bảo mật, như máy in lỗi hoặc mạng chậm; liên hệ IT Helpdesk.
- Quên mật khẩu mà không có dấu hiệu bị lộ; xem Chính sách mật khẩu và xác thực.

6. Mức độ nghiêm trọng

Trực SOC phân loại mức độ nghiêm trọng sau khi nhận báo cáo. Nhân sự không cần tự phân loại và mọi mức đều phải được báo trong cùng thời hạn 1 giờ kể từ khi phát hiện.

Mức	Mô tả	Ví dụ	Ưu tiên xử lý
Thấp	Nghi ngờ, chưa có tác động	Nhận thư lừa đảo chưa mở	Theo dõi và hướng dẫn
Trung bình	Tác động một thiết bị hoặc tài khoản, dữ liệu chưa nhạy cảm	Máy nhiễm mã độc không có dữ liệu Bí mật	Xử lý theo thứ tự ưu tiên
Cao	Ảnh hưởng dữ liệu Bí mật hoặc nhiều thiết bị	Tài khoản bị chiếm quyền có quyền cao	Xử lý ngay
Nghiêm trọng	Ảnh hưởng dữ liệu Tối mật hoặc hệ thống lõi	Nghi lộ mã nguồn lõi	Xử lý khẩn cấp, huy động lãnh đạo

Mức độ có thể được nâng hoặc hạ khi có thêm thông tin. Dữ liệu bị ảnh hưởng được đối chiếu với Chính sách phân loại dữ liệu: sự cố liên quan dữ liệu lương cá nhân thuộc Bí mật thường được xếp từ mức Cao.

7. Các bước xử lý

1. Không tự xử lý và không xóa dấu vết trên thiết bị.
2. Ngắt kết nối mạng của thiết bị (rút cáp mạng hoặc tắt Wi-Fi).
3. Báo cho Trực SOC trong vòng 1 giờ kể từ khi phát hiện qua kênh Trực SOC.
4. Ghi nhận mã sự cố do Trực SOC cung cấp và làm theo hướng dẫn tiếp theo.

7.1 Bước 1. Không tự xử lý và không xóa dấu vết

Không tự xử lý nghĩa là nhân sự không tự cài phần mềm diệt virus mới, không tự xóa tệp lạ, không tự cài lại hệ điều hành và không tự khôi phục từ bản sao lưu. Những thao tác này dễ xóa mất bằng chứng mà VinSOC cần để biết mã độc vào bằng cách nào và đã lấy đi những gì. Không tắt nguồn bằng cách rút điện nếu không có hướng dẫn; giữ nguyên các cửa sổ thông báo đang hiển thị và chụp ảnh màn hình bằng điện thoại cá nhân nếu có thể.

7.2 Bước 2. Ngắt kết nối mạng

Ngắt kết nối mạng để mã độc không lan sang thiết bị khác và kẻ tấn công không tiếp tục điều khiển máy từ xa. Rút cáp mạng hoặc tắt Wi-Fi. Không tắt máy trừ khi Trực SOC yêu cầu. Trường hợp thiết bị bị mất và không thể ngắt mạng, bỏ qua bước này và chuyển ngay sang bước báo cáo.

7.3 Bước 3. Báo cho Trực SOC

Báo cho Trực SOC trong vòng 1 giờ kể từ khi phát hiện. Thời hạn tính từ lúc nhân sự nhận ra sự việc, không phải từ lúc sự việc bắt đầu xảy ra và không phải từ giờ hành chính kế tiếp. Trực SOC hoạt động 24/7 nên sự cố phát hiện vào buổi tối, cuối tuần hoặc ngày lễ vẫn phải báo ngay.

7.4 Bước 4. Ghi nhận mã sự cố và làm theo hướng dẫn

Trực SOC phản hồi bằng mã sự cố và các hướng dẫn cụ thể như tiếp tục ngắt mạng, bàn giao máy cho VinSOC, đổi mật khẩu, thu hồi phiên đăng nhập hoặc cung cấp thêm thông tin. Nhân sự ghi lại mã sự cố và dùng mã đó trong mọi trao đổi tiếp theo.

8. Kênh báo cáo

Kênh báo cáo chính thức là Trực SOC qua email soc-oncall@vsf-demo.example, hoạt động 24/7. Không báo cáo sự cố qua nhóm chat chung, mạng xã hội hoặc trao đổi miệng với đồng nghiệp thay cho báo cáo chính thức, vì thông tin có thể bị lộ thêm và không được ghi nhận.

- Nếu thiết bị bị ảnh hưởng không thể gửi email, dùng một thiết bị khác đáng tin cậy để gửi báo cáo tới Trực SOC. Không đăng nhập tài khoản công ty trên thiết bị nghi bị nhiễm.
- Nếu không thể tự gửi, nhờ quản lý trực tiếp hoặc IT Helpdesk qua it-helpdesk@vsf-demo.example chuyển tiếp nội dung báo cáo tới Trực SOC; người chuyển tiếp ghi rõ thời điểm người phát hiện nhận ra sự việc.
- Quản lý trực tiếp không được yêu cầu nhân sự chờ hoặc xin phép trước khi báo cáo.

9. Thông tin cần cung cấp khi báo cáo

Thông tin	Cách cung cấp	Bắt buộc
Họ tên, mã nhân sự, đơn vị	Ghi ở đầu email	Có
Thời điểm và cách phát hiện	Giờ và ngày nhận ra sự việc	Có
Thiết bị hoặc tài khoản liên quan	Tên hoặc mã thiết bị, tên tài khoản	Có
Hiện tượng quan sát được	Mô tả ngắn, đính kèm ảnh chụp màn hình nếu có	Có
Đã làm gì	Nêu các bước đã thực hiện, ví dụ đã ngắt mạng	Có
Dữ liệu có thể bị ảnh hưởng	Loại dữ liệu và cấp độ nếu biết	Nên có
Vị trí hiện tại của thiết bị	Tại văn phòng, tại nhà hoặc thất lạc	Có

Nhân sự không gửi mật khẩu, mã xác nhận hoặc dữ liệu nhạy cảm trong nội dung báo cáo. Nếu chưa có đủ thông tin, vẫn báo trước và bổ sung sau; không trì hoãn báo cáo để chờ điều tra thêm.

10. Xử lý theo từng loại sự cố

10.1 Nghi nhiễm mã độc

- Ngắt mạng, không tắt máy nếu chưa có hướng dẫn, không tự xóa tệp.
- Không cắm USB hoặc ổ đĩa ngoài vào máy đang nghi nhiễm.
- Báo Trực SOC và chờ hướng dẫn bàn giao máy.

10.2 Mất hoặc thất lạc thiết bị công ty

- Báo Trực SOC ngay khi phát hiện mất, kể cả khi chưa chắc thiết bị bị lấy cắp.
- Nêu rõ thiết bị có dữ liệu Bí mật hoặc Tối mật hay không và thiết bị có mã hóa ổ đĩa hay không.
- Trực SOC phối hợp IT Helpdesk khóa tài khoản, thu hồi phiên đăng nhập và xóa dữ liệu từ xa nếu có thể.
- Nếu mất do trộm cắp, thực hiện thủ tục trình báo theo hướng dẫn của Trực SOC và quản lý.

10.3 Nghi tài khoản bị chiếm quyền

- Ngắt mạng thiết bị nếu nghi thiết bị cũng bị ảnh hưởng và báo Trực SOC.

- Không tự đổi mật khẩu trước khi Trực SOC hướng dẫn, vì việc đổi sai thời điểm có thể làm mất dấu vết.
- Từ chối mọi yêu cầu xác nhận MFA không do mình thực hiện.
- Làm theo hướng dẫn về đổi mật khẩu và đăng ký lại MFA theo Chính sách mật khẩu và xác thực.

10.4 Lộ hoặc gửi nhầm dữ liệu

- Không cố thu hồi hoặc xóa bằng cách gửi thêm nhiều thư cho nhiều người.
- Báo Trực SOC, nêu người nhận nhầm và loại dữ liệu; Trực SOC hướng dẫn thu hồi và đề nghị người nhận xóa.
- Cấp độ dữ liệu quyết định mức độ nghiêm trọng, ví dụ dữ liệu Bí mật thuộc mức Cao.

10.5 Bấm vào liên kết lừa đảo

- Ngắt mạng thiết bị, không nhập thêm thông tin và báo Trực SOC ngay.
- Nếu đã nhập mật khẩu, nêu rõ điều này khi báo cáo để Trực SOC thu hồi phiên đăng nhập sớm.

11. Sau khi báo cáo

1. Trực SOC xác nhận đã tiếp nhận, cấp mã sự cố và đánh giá sơ bộ mức độ.
2. Nhân sự làm theo hướng dẫn, bao gồm bàn giao thiết bị hoặc cung cấp thông tin bổ sung khi được yêu cầu.
3. VinSOC điều tra, thu thập bằng chứng, loại bỏ nguyên nhân và khôi phục hệ thống hoặc thiết bị.
4. IT Helpdesk cấp lại thiết bị hoặc tài khoản khi VinSOC cho phép.
5. VinSOC thông báo kết quả cho nhân sự và đóng sự cố, kèm khuyến nghị phòng ngừa.
6. Khối Công nghệ thông tin và các đơn vị liên quan rà soát bài học kinh nghiệm để cập nhật quy định hoặc đào tạo.

Nhân sự không thảo luận công khai về sự cố hoặc đưa thông tin ra bên ngoài khi sự cố chưa đóng. Mọi thông báo với khách hàng hoặc cơ quan chức năng do lãnh đạo có thẩm quyền quyết định theo đề xuất của VinSOC.

12. Ví dụ minh họa

Ví dụ 1. Một nhân sự đang làm việc từ xa vào buổi tối thấy màn hình xuất hiện thông báo yêu cầu trả tiền để mở khóa tệp. Nhân sự rút cáp mạng, không tắt máy, chụp ảnh màn hình bằng điện thoại cá nhân và dùng điện thoại gửi email cho Trực SOC trong vòng 1 giờ. Trực SOC cấp mã sự cố và hướng dẫn bàn giao máy vào ngày làm việc kế tiếp.

Ví dụ 2. Một nhân sự phát hiện thiếu laptop công ty sau chuyến đi công tác. Dù chưa chắc thiết bị bị lấy cắp hay chỉ để quên, nhân sự vẫn báo Trực SOC trong vòng 1 giờ kể từ khi phát hiện. Trực SOC phối hợp IT Helpdesk thu hồi phiên đăng nhập; sau đó thiết bị được tìm thấy nhưng sự cố vẫn được ghi nhận và đóng có kết luận.

Ví dụ 3. Một nhân sự nhận nhiều yêu cầu xác nhận MFA trong khi không đăng nhập. Nhân sự từ chối các yêu cầu, báo Trực SOC và chờ hướng dẫn về đổi mật khẩu thay vì tự đổi ngay, để Trực SOC xem nhật ký đăng nhập trước.

Ví dụ 4. Một nhân sự gửi nhầm bảng lương cá nhân vào nhóm chat chung. Nhân sự không xóa hàng loạt mà báo Trực SOC ngay, nêu loại dữ liệu và nhóm chat; Trực SOC hướng dẫn thu hồi tin nhắn và đề nghị các thành viên không chuyển tiếp.

13. Vi phạm và xử lý

Che giấu sự cố, báo muộn so với thời hạn 1 giờ mà không có lý do chính đáng, cố ý xóa dấu vết hoặc tự xử lý khiến mất bằng chứng là vi phạm và được xử lý theo Nội quy lao động. Ngược lại, nhân sự báo sớm, trung thực và hợp tác thường được xem là yếu tố giảm nhẹ; mục tiêu của quy trình là khắc phục nhanh, không phải quy trách nhiệm cá nhân.

14. Câu hỏi thường gặp

Hỏi: Tôi phải báo sự cố trong bao lâu? Đáp: Trong vòng 1 giờ kể từ khi phát hiện, cho tất cả các mức độ nghiêm trọng.

Hỏi: Tôi báo cho ai? Đáp: Cho Trực SOC qua email soc-oncall@vsf-demo.example; Trực SOC hoạt động 24/7.

Hỏi: Máy nghi nhiễm mã độc thì làm gì trước tiên? Đáp: Không tự xử lý và không xóa dấu vết, sau đó ngắt kết nối mạng bằng cách rút cáp mạng hoặc tắt Wi-Fi rồi báo Trực SOC.

Hỏi: Tôi có nên tắt máy không? Đáp: Không, trừ khi Trực SOC yêu cầu; hãy ngắt mạng thay vì tắt máy.

Hỏi: Tôi chưa chắc đó là sự cố thì có phải báo không? Đáp: Có, khi nghi ngờ thì báo cáo. Báo nhầm không bị xử lý.

Hỏi: Phát hiện sự cố lúc nửa đêm thì sao? Đáp: Vẫn báo ngay vì Trực SOC hoạt động 24/7; không chờ đến giờ hành chính.

Hỏi: Tôi bị mất điện thoại đã đăng ký MFA, có phải báo Trực SOC không? Đáp: Có nếu có nguy cơ lộ tài khoản, và đồng thời báo IT Helpdesk để đăng ký lại MFA.

Hỏi: Tôi có nên đổi mật khẩu ngay khi nghi tài khoản bị chiếm quyền không? Đáp: Báo Trực SOC trước và làm theo hướng dẫn về thời điểm đổi mật khẩu.

Hỏi: Mã sự cố dùng để làm gì? Đáp: Để theo dõi và trao đổi về sự cố; do Trực SOC cung cấp sau khi tiếp nhận báo cáo.

Hỏi: Quản lý của tôi bảo đợi đến sáng mai thì sao? Đáp: Vẫn báo Trực SOC trong vòng 1 giờ; quản lý không được yêu cầu trì hoãn báo cáo.

15. Phụ lục

15.1 Phụ lục A. Mẫu email báo cáo sự cố

Gửi tới: soc-oncall@vsf-demo.example. Tiêu đề: Báo cáo sự cố bảo mật - [Loại sự cố] - [Họ tên]. Nội dung: Tôi là [họ tên], mã nhân sự [mã], thuộc [đơn vị]. Lúc [giờ, ngày] tôi phát hiện [mô tả hiện tượng] trên [thiết bị hoặc tài khoản]. Tôi đã [các bước đã thực hiện, ví dụ ngắt mạng bằng cách tắt Wi-Fi] và chưa xóa bất kỳ tệp nào. Thiết bị hiện ở [vị trí]. Dữ liệu có thể liên quan: [loại dữ liệu, cấp độ nếu biết]. Tôi có thể liên hệ qua [kênh liên lạc].

15.2 Phụ lục B. Danh sách kiểm tra nhanh khi nghi ngờ sự cố

- Không tự xử lý, không xóa dấu vết.
- Ngắt mạng thiết bị bằng cách rút cáp mạng hoặc tắt Wi-Fi.
- Ghi lại thời điểm phát hiện và chụp ảnh màn hình nếu có thể.
- Báo Trực SOC trong vòng 1 giờ qua soc-oncall@vsf-demo.example.
- Ghi nhận mã sự cố và làm theo hướng dẫn.
- Không thảo luận sự cố ở nơi công cộng hoặc nhóm chat chung.

15.3 Phụ lục C. Bảng tra cứu nhanh

Tình huống	Việc đầu tiên	Báo cho ai
Nghi nhiễm mã độc	Ngắt mạng, không tự xử lý	Trực SOC
Mất thiết bị công ty	Báo ngay	Trực SOC
Nghi tài khoản bị chiếm quyền	Báo, chờ hướng dẫn đổi mật khẩu	Trực SOC
Gửi nhầm dữ liệu	Không xóa hàng loạt, báo ngay	Trực SOC
Quên mật khẩu bình thường	Liên hệ hỗ trợ	IT Helpdesk

16. Lịch sử sửa đổi

Phiên bản	Ngày	Nội dung thay đổi
1.0	2023-03-01	Ban hành quy trình báo cáo sự cố bảo mật gồm các bước cơ bản
1.1	2023-09-01	Bổ sung danh mục các trường hợp phải báo cáo
1.2	2024-02-01	Bổ sung mức độ nghiêm trọng và thông tin cần cung cấp khi báo cáo
1.3	2024-09-01	Bổ sung xử lý theo từng loại sự cố, các bước sau báo cáo, ví dụ minh họa và câu hỏi thường gặp